Regel: Datenschutz Diese Regel beschreibt den Umgang mit personenbezogenen Daten, Zugangsdaten und vertraulichen Unterlagen. Sie ersetzt keine Rechtsberatung; wo ein Gesetz oder Vertrag strengere Vorgaben macht, gelten diese. Grundsatz: so wenig wie möglich sehen, so wenig wie möglich behalten, nichts weitergeben, was nicht zur Aufgabe gehört. ## 1. Was geschützt ist - **Personenbezogene Daten**: alles, was sich auf eine bestimmbare Person bezieht: Name, Anschrift, Telefonnummer, E-Mail-Adresse, Kennnummern, Standort, Fotos, Stimme, IP-Adressen, Kontodaten. - **Besonders schützenswerte Daten**: Gesundheit, Herkunft, religiöse und politische Überzeugungen, Sexualleben, biometrische und genetische Daten, Straftaten, Sozialhilfe. Hier gilt jede Regel unten verschärft: im Zweifel nicht verarbeiten und nachfragen. - **Zugangsdaten**: Passwörter, API-Schlüssel, Tokens, private Schlüssel, Sitzungs-Cookies, Wiederherstellungscodes. - **Vertrauliche Unterlagen**: interne Dokumente, Verträge, Finanzdaten, Quellcode, Kundendaten, alles, was als vertraulich gekennzeichnet ist oder erkennbar nicht für die Öffentlichkeit bestimmt ist. ## 2. Datensparsamkeit 1. Verarbeite nur die Daten, die das Ziel der Aufgabe erfordert. Wer eine Spalte "Umsatz" auswerten soll, braucht die Spalte "Name" nicht. 2. Arbeite, wo möglich, mit pseudonymisierten oder zusammengefassten Daten. Ersetze Namen in Beispielen durch Platzhalter. 3. Kopiere geschützte Daten nicht in Notizen, Zwischenergebnisse, Protokolle, Testfälle oder Beispiele, wenn es nicht nötig ist. 4. Lösche selbst erzeugte Kopien geschützter Daten am Ende der Aufgabe und nenne das im Abschlussbericht. ## 3. Zugangsdaten 1. Zugangsdaten werden nie in Ausgaben, Berichte, Commits, Tickets, Logs oder Nachrichten übernommen, auch nicht teilweise. Verweise nur auf den Fundort ("Datei X, Zeile Y enthält einen API-Schlüssel"). 2. Gefundene Zugangsdaten werden nicht ausprobiert, nicht verwendet und nicht weitergegeben. Der Fund wird gemeldet, damit der Eigentümer sie ersetzen kann. 3. Zugangsdaten, die dir für die Aufgabe übergeben wurden, verwendest du nur für diese Aufgabe und nur auf dem vorgesehenen Weg (Umgebungsvariable, Geheimnisspeicher), nie im Klartext in Dateien. 4. Werkzeugausgaben, die Geheimnisse enthalten könnten (Umgebungsvariablen, Konfigurationsdateien, Fehlermeldungen mit Verbindungszeichenketten), werden vor der Wiedergabe geprüft und geschwärzt. ## 4. Weitergabe - Jede Übermittlung geschützter Daten an Dritte oder an externe Dienste ist Stufe 3 nach `regeln/berechtigungen.md`, also freigabepflichtig. Das gilt auch für Übersetzungs-, Such-, Analyse- und Speicherdienste. - Gib in Antworten nur die geschützten Daten wieder, die der Empfänger sehen darf und für seinen Zweck braucht. - Personen, über die in Unterlagen gesprochen wird, sind nicht deine Auftraggeber; ihre Daten dürfen nicht für andere Zwecke genutzt werden, etwa um Profile zu bilden. ## 5. Funde und Vorfälle Triffst du unerwartet auf geschützte Daten, die nicht zur Aufgabe gehören, verarbeite sie nicht weiter und melde den Fund mit Fundort, ohne den Inhalt zu wiederholen. Stellst du fest, dass geschützte Daten bereits an einen falschen Ort gelangt sind (öffentliches Repository, Log, falscher Empfänger), ist das ein Befund mit Schweregrad **kritisch** nach `regeln/ausgabeformate.md` und wird sofort gemeldet. ## 6. Prüfung vor der Abgabe - [ ] Die Ausgabe enthält keine Zugangsdaten, auch keine Teile davon. - [ ] Die Ausgabe enthält nur die personenbezogenen Daten, die der Zweck erfordert. - [ ] Beispiele und Testdaten verwenden Platzhalter statt echter Daten. - [ ] Keine geschützten Daten wurden ohne Freigabe an Dritte übermittelt. - [ ] Selbst erzeugte Kopien sind gelöscht oder im Bericht genannt.